SECURITY OPERATIONS / PRACTICAL EMAIL TRIAGE

EMAIL PHISHING & THREAT ANALYSIS

Four sample-based case studies from a SOC L1 perspective



SOC ANALYST PORTFOLIO | NOV 2026

PREPARED BY

VIPIN KUMAR

Email security analysis | Phishing triage | Incident response fundamentals

WHY I DID THIS PROJECT

To practise a repeatable SOC L1 email-triage process: validate sender identity and authentication, recognize social-engineering tactics, inspect suspicious links and attachments safely, and translate technical evidence into clear incident findings.

WHAT THIS PROJECT DEMONSTRATES

Four distinct cases: donation/advance-fee lure, bank-refund PDF impersonation, crypto KYC brand impersonation, and suspicious casino promotion. Practised header review (SPF/DKIM/DMARC), sender and Reply-To checks, static PDF/link inspection, SHA-256 hashing, IOC documentation, risk assessment and response recommendations.

DATASET & SAMPLE ATTRIBUTION

Source repository: **github.com/rf-peixoto/phishing_pot/**

Samples reviewed: **sample-4.eml | sample-406.eml | sample-20.eml | sample-48.eml**

CONNECT

LINKEDIN **linkedin.com/in/vipin-kumar-530a55283/**

GITHUB **github.com/vipinsky**

SCOPE & RESPONSIBLE HANDLING

Educational, retrospective analysis of the four supplied email samples. Suspicious destinations were not opened. Conclusions are based on observable message/header content and static attachment inspection; recipient activity, endpoint impact and successful compromise were not established.

SOC ANALYST PORTFOLIO / PRACTICAL EMAIL TRIAGE

EMAIL THREAT INVESTIGATION

Four sample-based phishing and suspicious email case studies

Project overview

This portfolio documents the triage of four suspicious email samples. The goal was to understand who appeared to send each message, whether the sender authenticated correctly, what social-engineering technique was used, and which links or attachments required further review.

Cases investigated

01 Donation lure	Advance-fee / donation scam pattern | High-confidence phishing
02 IRPF refund	Banco do Brasil impersonation through a PDF attachment | High-confidence phishing
03 Kraken KYC	Crypto-account verification lure with a mismatched action link | High-confidence phishing
04 Wildsino offer	Casino promotion with sender-authentication failures and redirect-style links | Suspicious spam; phishing unconfirmed

Investigation approach

- Reviewed sender, Reply-To, Return-Path, Received headers and Microsoft filtering fields.
- Interpreted SPF, DKIM and DMARC results in the context of the visible sender identity.
- Reviewed message wording, urgency, financial or account-related lures and call-to-action links.
- Extracted and statically inspected the PDF attachment, calculated its SHA-256 hash and identified its embedded URL.
- Recorded indicators, confidence levels, limitations and practical response recommendations.

Scope and evidence note

This is a retrospective analysis of the supplied samples. The suspicious destinations were extracted from message or PDF content but were not opened. No recipient click logs, endpoint telemetry, credential-submission evidence, sandbox detonation or external reputation verdicts were supplied. Therefore, user impact and successful compromise are not claimed.

Analysis dates represented in the samples: July 2023 to July 2026.

CASE STUDY 01 / 04 | DONATION / ADVANCE-FEE LURE

Donation For You - $10.5 Million Offer

Sample date: 2 August 2023 | Message presented as a personal philanthropic donation

VERDICT: HIGH-CONFIDENCE PHISHING - ADVANCE-FEE / DONATION SCAM

Email snapshot

From	Philip Fredrick <ghulammustafa@cyber.net.pk>
Reply-To	philipffredrick3690@gmail.com
Subject	86RE: Donation For You
Recipient	Undisclosed recipients
Observed IPs	159.27.24.86 (sending relay); 147.78.103.9 (earlier SMTP connection)

Why it was investigated

The sender claims to be a philanthropist distributing USD 10.5 million to randomly selected people worldwide. The recipient is told to confirm that the email address is valid by replying to a different Gmail address. An unsolicited, unusually large donation combined with a request to initiate contact is a strong social-engineering warning sign.

Key evidence

Sender mismatch	The visible sender uses cyber.net.pk, while Reply-To directs replies to a separate Gmail account.
Authentication	SPF: SoftFail; DKIM: none; DMARC: fail; Microsoft X-SID-Result: FAIL.
Mail filtering	Microsoft SCL: 7; mailbox delivery metadata indicates Junk.
Distribution	The recipient field is 'Undisclosed recipients', consistent with a bulk or mass-distributed message.
Header timing	The Date header (19:27:50 -0700) is about seven hours later than the earliest Received timestamp (19:27:40 UTC) after timezone conversion.
Message content	Promises a random USD 10.5 million donation and asks the recipient to email the Reply-To address to confirm the account is active.

Analyst assessment

The combination of a large unsolicited donation promise, sender/Reply-To mismatch and failed or missing authentication strongly supports an advance-fee / donation-scam classification. The supplied message asks for an email reply; it does not itself request an upfront fee or contain a payment link. Any later fee demand or collection of personal data would need separate evidence.

Recommended SOC response

- Quarantine the message and search the mail environment for the sender, Reply-To, subject and message ID.
- Block or otherwise contain the exact sender indicators according to organizational policy; do not treat the observed relay IP as a universal block candidate without validation.
- Check for replies or follow-on messages to determine whether recipients engaged with the sender.
- Preserve the original message and headers for incident records.

Key indicators: ghulammustafa@cyber.net.pk | philipffredrick3690@gmail.com | 159.27.24.86 | 147.78.103.9 | Subject: 86RE: Donation For You

CASE STUDY 02 / 04 | BANK IMPERSONATION / PDF LURE

IRPF Refund - Banco do Brasil Impersonation

Sample date: 26 July 2023 | Financial refund claim delivered with a PDF attachment

VERDICT: HIGH-CONFIDENCE PHISHING - BANK IMPERSONATION

Email snapshot

From	"[BB] - Seu saldo foi liberado" <prestonconstance587@gmail.com>
Subject	Liberação de IRPF - 6NwlyfzWcsNerv0
Attachment	csWuYjyqO2IR.pdf (97,566 bytes; 1 page)
Authentication	SPF: PASS; DKIM: PASS; DMARC: PASS - all aligned to gmail.com
Mail filtering	Microsoft SCL: 1 (low spam confidence score)

Why it was investigated

The message says a balance is available for credit and directs the recipient to an attachment for more information. The sender's display name suggests a bank notification, but the actual address is a personal Gmail account.

Attachment and URL findings

Visual content	The PDF imitates a Banco do Brasil notification and claims a refund of R$ 4,593.21. A prominent 'CLIQUE AQUI' button promises credit within 24 hours.
Embedded URL	hxxps://okokoaksoa[.]z13[.]web[.]core[.]windows[.]net/
PDF structure	Static inspection found one page, no encryption, no JavaScript reported by pdfinfo, and one external URI link annotation.
SHA-256	cfc5fbc759dcc599c8329dd94f9364394c7b1e875d6ff515c7337e00fb1f30cf
Authentication context	The passing SPF, DKIM and DMARC results authenticate Gmail infrastructure/domain alignment, not Banco do Brasil or the bank claim.

Analyst assessment

This is a high-confidence bank-impersonation phishing attempt. The financial refund lure, bank-branded PDF, prominent action button and unrelated Azure-hosted destination form a coherent phishing chain. The low SCL score demonstrates why a gateway score should not replace content and attachment analysis. The destination was not opened, so its live behavior remains unverified.

Recommended SOC response

- Quarantine the email; search for the sender, attachment name, SHA-256 and exact hostname across mail and security logs.
- Block the exact suspicious hostname after validation and follow the organization's URL-blocking process.
- Review proxy, DNS and endpoint telemetry to identify users who accessed the destination or downloaded further content.
- If credentials or financial information were submitted, escalate for account protection and incident response.

Key indicators: prestonconstance587@gmail.com | csWuYjyqO2IR.pdf | okokoaksoa[.]z13[.]web[.]core[.]windows[.]net | SHA-256 listed above

CASE STUDY 03 / 04 | CRYPTOCURRENCY ACCOUNT VERIFICATION LURE

Kraken - Additional Identity Verification

Sample date: 3 June 2026 | KYC and account-restriction pressure

VERDICT: HIGH-CONFIDENCE PHISHING - BRAND IMPERSONATION

Email snapshot

From	Kraken <jelena.beronja@eurowolk.rs>
Reply-To	Kraken <info@Tiger.de>
Subject	[Kraken] Action Required: Additional Identity Verification - Your Account Needs Attention
Sender relay	www1.burina.net - 87.118.110.34
Earlier connection	207.246.110.46

Why it was investigated

The message claims Kraken requires additional KYC information and warns that storing, transferring and withdrawing funds may be restricted unless the user acts. It also asks the recipient to accept updated Terms of Service, creating urgency around an account-security action.

Key evidence

Brand / sender mismatch	The display name says Kraken, but the sender domain is eurowolk.rs. Reply-To points to info@Tiger.de, a third, unrelated domain.
Authentication	SPF: PASS for eurowolk.rs; DKIM: TIMEOUT (key query timeout); DMARC: PASS for eurowolk.rs. These results do not authenticate the Kraken brand.
Primary CTA	The 'I agree' button links to hxxps://soulsystem[.]co.
Other links	The message's Sign in and Support links point to app.kraken.com and support.kraken.com, while the primary agreement button points elsewhere.
Mail filtering	Microsoft SCL: 5; mailbox delivery metadata indicates Junk.

Analyst assessment

The unrelated sender and Reply-To domains, combined with a KYC/account-restriction lure and a primary action button leading to soulsystem[.]co, strongly indicate brand-impersonation phishing. A DKIM timeout is inconclusive, not a DKIM failure. The message's passing SPF/DMARC results apply to eurowolk.rs and do not prove that Kraken sent it. The destination was not opened, so credential collection is not confirmed.

Recommended SOC response

- Quarantine the message and hunt for the sender, Reply-To address, exact CTA URL and message ID.
- Block the exact suspicious destination after threat-intelligence and organizational validation.
- Review DNS, proxy and browser telemetry for requests to soulsystem[.]co.
- If a user submitted credentials, initiate the account-compromise playbook, including password reset and session revocation.

Key indicators: jelena.beronja@eurowolk.rs | info@Tiger.de | soulsystem[.]co | 87.118.110.34 | 207.246.110.46

CASE STUDY 04 / 04 | CASINO PROMOTION / SUSPICIOUS SPAM

Wildsino - Free Spins Promotional Lure

Sample date: 8 July 2026 | Gambling promotion with external tracking-style links

VERDICT: HIGH-CONFIDENCE SPAM; PHISHING NOT CONFIRMED

Email snapshot

From	Wildsino casino rewards <morgan.williams@kiofrozenkings2501.onmicrosoft.com>
Subject	Exclusive Offer Inside: 300 Free Spins for New Players at Wildsino bonus!
Sender IP	209.85.218.50 (Google mail relay shown in the receiving headers)
Authentication	SPF: FAIL; DKIM: PASS but not aligned to the From domain; DMARC: none
Mail filtering	X-SID-Result: FAIL; Microsoft SCL: 8; mailbox delivery metadata indicates Junk.

Why it was investigated

The message promotes casino registration with a large bonus and free spins. The sender uses an onmicrosoft.com address rather than a recognizable Wildsino sender domain, and the message's main calls to action lead to a separate domain.

Key evidence

Authentication	SPF fails for kiofrozenkings2501.onmicrosoft.com. DKIM passes for a gappssmtp.com signing domain that does not align with the visible From domain. DMARC is reported as none.
Offer inconsistency	The subject advertises 300 free spins, while the visible body advertises 200 free spins and a 100% bonus up to $750.
Link destination	The main promotional buttons point to woondsplay[.]com with multiple tracking-style query parameters.
HTML structure	The HTML includes a large hidden block of random-looking text. This is an anomaly, but its purpose cannot be confirmed from the sample alone.
Filtering	Microsoft assigned SCL 8 and classified the message as Junk.

Analyst assessment

The email is clearly unsolicited gambling promotion and high-confidence spam. Authentication failures, a sender domain unrelated to the advertised brand, offer inconsistency and external tracking-style links make it suspicious and suitable for further URL investigation. However, the supplied message does not prove credential harvesting, malware delivery or a successful phishing compromise. It is therefore reported as suspicious spam / potential phishing rather than confirmed credential phishing.

Recommended SOC response

- Keep the message in Junk or quarantine and search for the sender, subject and woondsplay[.]com links.
- Review secure web gateway, DNS and browser telemetry for visits to the exact linked URLs.
- Block confirmed malicious URLs or domains according to policy; avoid blocking the shared Google relay IP based solely on this message.
- Escalate if the destination requests credentials, payment details or downloads, or if user interaction is observed.

Key indicators: morgan.williams@kiofrozenkings2501.onmicrosoft.com | woondsplay[.]com | SPF fail | SCL 8

PORTFOLIO SUMMARY / ANALYST WORKFLOW

What the investigation demonstrated

The four samples show why phishing triage must correlate email identity, authentication results, message content, links and attachments. No single signal was treated as a verdict.

Case outcome at a glance

Sample	Main evidence	Assessment
01 Donation	SPF SoftFail, DKIM none, DMARC fail, sender/Reply-To mismatch, large unsolicited donation promise.	High-confidence phishing
02 IRPF refund	Bank-branded PDF, refund lure, external Azure-hosted link; SPF/DKIM/DMARC passed for Gmail.	High-confidence phishing
03 Kraken KYC	Brand/sender mismatch, unrelated Reply-To and 'I agree' link to soulsystem[.]co.	High-confidence phishing
04 Wildsino	SPF fail, DKIM non-alignment, DMARC none, SCL 8 and promotional links to woondsplay[.]com.	High-confidence spam; phishing unconfirmed

Repeatable SOC L1 workflow

- Preserve the original message and collect full headers before taking action.
- Compare From, Reply-To and Return-Path; trace Received hops and interpret SPF, DKIM and DMARC against the actual sending domain.
- Review the subject and body for urgency, unusual financial claims, account restrictions, unsolicited rewards and requests to reply or click.
- Inspect attachments statically: identify file type, calculate hashes, extract content and URLs, and render documents without activating links.
- Correlate indicators with mail, DNS, proxy, browser and endpoint telemetry; determine whether a user interacted with the message.
- Contain confirmed threats, protect affected accounts when required, and document the evidence and remaining unknowns.

Tools and techniques used

Python email/MIME parsing | Email header and authentication review | Static PDF inspection with PyMuPDF and pdfinfo | PDF rendering | URL extraction | SHA-256 hashing | IOC documentation

Limitations and responsible reporting

The analysis is based only on the four supplied samples. No live links were opened, no external reputation service results are claimed, and no sandbox detonation or recipient endpoint/mailbox telemetry was available. The report therefore identifies evidence and risk, not confirmed user compromise. The Wildsino sample is intentionally classified as suspicious spam / potential phishing because the available evidence does not establish credential theft.

Resume-ready project description

Email Phishing Investigation Lab | Conducted sample-based triage of four suspicious emails covering donation/advance-fee scams, bank impersonation, cryptocurrency KYC lures and suspicious casino promotions. Analyzed SPF/DKIM/DMARC, sender and Reply-To mismatches, mail-filtering headers and social-engineering indicators; statically inspected a PDF attachment, extracted its SHA-256 hash and embedded URL, documented IOCs, and prepared incident-response recommendations.